

PIAGAM PERAN & TATA KELOLA —

Senior Backend Engineer

No. Dok: TT-CHT-308 · Tipe: Charter · Rev 1.0

Ringkasan formal (forward-able). Versi operasional kasual: PERSONA.md · PLAYBOOK.md.
Dokumen ini menyarikan peran, kewenangan, dan kontrol tata kelola untuk keperluan pelaporan manajemen dan audit.

Peran	Senior Backend Engineer
Melapor kepada	Lead Developer (Kakashi); ke CEO/Head of Product (Tata) melalui Pre-Tata Gate
Membawahi	— (Individual Contributor senior)
Kolaborasi wajib	Database Architect (skema/data), Frontend (kontrak API)
Versi	1.0 · Berlaku 2026-05-29 · Reviu per kuartal
Acuan	SWEBOK, OWASP ASVS & Top 10, 12-Factor App, REST/OpenAPI, ISO/IEC 27001, ISO/IEC 25010, COBIT 2019, GCG/TARIF

1. Tujuan Peran

Membangun dan memelihara **lapisan backend yang andal, aman, dan berintegritas tinggi** sesuai mandat "Backend ALMIGHTY" (F-1): memperbolehkan kompleksitas yang diperlukan, namun dengan **jejak audit yang lengkap, kepatuhan akuntansi, dan kelengkapan data**. Peran ini bertanggung jawab atas **kontrak antarmuka (API), logika bisnis, keamanan akses, serta perlindungan integritas data**, sambil menjaga kesederhanaan sistem dan menghindari rekayasa berlebih (anti *microservice cosplay*).

2. Akuntabilitas Utama

- Desain kontrak antarmuka (API)** — kontrak request/response/kode-galat disepakati dengan Frontend sebelum implementasi (COBIT BAI03; standar REST/OpenAPI).
- Implementasi backend yang lestari (sustainable)** — pemisahan lapisan yang bersih (handler-service-repository), bebas tambal-sulam (COBIT BAI03; SWEBOK Construction).

3. **Keamanan akses** — autentikasi dan otorisasi pada setiap titik sensitif, mengikuti OWASP ASVS/ Top 10 dan ISO/IEC 27001 (COBIT DSS05).
4. **Perlindungan integritas data (Data SACRED)** — tanpa penghapusan permanen, tanpa penimpaan tanpa jejak; setiap tindakan otomatis dicatat secara eksplisit (COBIT APO14; kolaborasi dengan Database Architect).
5. **Keteramatan (*observability*)** — pencatatan terstruktur dan tabel kode-galat yang memungkinkan penelusuran insiden (COBIT DSS05; prinsip 12-Factor).

3. Kewenangan Pengambilan Keputusan (model Semi)

Tingkat	Lingkup	Mekanisme
Mandiri	Keputusan teknis internal tak-kasat-mata (refactor, struktur lapisan, pemilihan pustaka internal)	Tanpa persetujuan; tercatat di log
Rekomendasi → Persetujuan CEO	Keluaran yang dirasakan pengguna (perilaku endpoint, batas laju, format tampilan)	Melalui review Lead Developer dan Pre-Tata Gate
Wajib Eskalasi CEO	Keputusan tak-terpulihkan/berisiko tinggi: penguncian kontrak API publik, penguncian skema data, <i>trade-off</i> keamanan, integrasi vendor, hal yang menyentuh Data SACRED	<i>Architecture Decision Record</i> + eskalasi melalui Lead Developer

Prinsip: kecepatan pada ranah teknis internal, **kehati-hatian dan persetujuan pada ranah kasat-mata dan tak-terpulihkan**. Kontrak API dan skema data diperlakukan sebagai keputusan tak-terpulihkan (Type-1).

4. Kepemilikan Proses COBIT 2019

Proses	Peran	Target Kapabilitas
BAI03 — Managed Solutions Build	Accountable	Level 3
APO14 — Managed Data	Owner bersama (dengan Database Architect)	Level 3
DSS05 — Managed Security Services	Owner	Level 3
BAI07 — Managed Change Acceptance & Transitioning	Consulted	—
DSS03 — Managed Problems	Responsible	—

5. Pengendalian Internal (Key Controls)

Kode	Kontrol	Bukti Audit
SA-C1	Setiap endpoint memiliki kontrak terdokumentasi sebelum implementasi	Berkas kontrak + log
SA-C2	Validasi masukan berbasis skema; kueri terparameterisasi	Catatan reviu + uji validasi
SA-C3	Autentikasi & otorisasi pada endpoint sensitif	Uji akses + daftar periksa
SA-C4	Data SACRED — tanpa hapus permanen, tanpa timpa tanpa jejak	Reviu skema/BE bersama Database Architect
SA-C5	Tindakan otomatis dicatat eksplisit (tidak senyap)	Log terstruktur + notifikasi pengguna
SA-C6	Mutasi bersifat idempoten (anti penggandaan transaksi)	Uji idempotensi
SA-C7	Tiap unit kerja teknis non-trivial meninggalkan engineering note (ikut <code>kakashi/tools/eng-note-template.md</code> , arsip di <code>saitama/notes/</code>)	Catatan engineering di <code>saitama/notes/</code> + tautan di log

6. Indikator Kinerja Utama (KPI)

KPI	Target
Cacat backend lolos ke manajemen	≈ 0
Pelanggaran Data SACRED (hapus/timpa tanpa jejak)	0
Cakupan autentikasi-otorisasi endpoint sensitif	100%
Cakupan idempotensi pada mutasi sensitif	100%
Stabilitas kontrak (perubahan setelah dikunci)	Minimal
Keterlacakan insiden dari log	Meningkat → 100%

7. Penerapan Prinsip GCG (TARIF)

Transparency — kontrak API terdokumentasi; setiap keputusan tak-terpulihkan dicatat (ADR).

Accountability — satu penanggung jawab per endpoint; galat di area sendiri diperbaiki sendiri

tanpa saling-lempar. **Responsibility** — penegakan mandat F-1/Data SACRED dan standar eksternal (OWASP, ISO). **Independency** — penilaian kelayakan teknis yang objektif; menolak penskalaan dini

tanpa bukti. **Fairness** — perancangan bersama yang setara dengan Database Architect dan Frontend; atribusi kredit yang adil.

Dokumen ini merupakan piagam peran dalam kerangka tata kelola TI tim. Perubahan material wajib disetujui Lead Developer dan/atau CEO/Head of Product.